

UNIVERSITI KUALA LUMPUR
MALAYSIAN INSTITUTE OF INFORMATION TECHNOLOGY (UniKL MIIT)

RESEARCH METHODOLOGY SELECTION HANDBOOK

A Student Guide for Cybersecurity Research and Final Year Projects

Applies to: IDB30102 / Final Year Project
Edition 1 — July 2026 Semester

Contents

1. Purpose of This Handbook

Chapter 3 of a research proposal is where most cybersecurity projects are won or lost. The recurring weakness is not poor technical work — it is that students name a software process model, such as Waterfall or Agile, and call it their research methodology. That statement says nothing about how the research problem will be investigated, what data will be used, or how the result will be shown to work.

This handbook sets out how to choose and justify a methodology. It applies to all research areas assigned in Assignment 2 (Groups A to Z) and remains valid for the Final Year Project.

How to use it

1. Read Section 2 to understand the two-layer structure that Chapter 3 must follow.
2. Use Section 3 to select your research methodology. Every project must have one.
3. Use Section 4 to select a development model — only if you are building something.
4. Check Section 5 for the suggested pairing for your assigned research area.
5. Cite the relevant domain standard from Section 6 instead of inventing your own process diagram.
6. Complete the evaluation plan in Section 7 and the ethical declaration in Section 8 before you submit.
7. Run the checklist in Section 9 against your draft.

2. The Two Layers of Chapter 3

A research proposal must separate two different things that are often confused.

Layer	What it answers	Examples
Layer 1 — Research Methodology (compulsory)	How the research problem will be investigated, what evidence will be gathered, and how the outcome will be judged. This is the scientific logic of the study.	Design Science Research, Experimental, CRISP-DM, Security Assessment, Threat Modelling, Case Study, Survey, Forensic Process
Layer 2 — Development Model (only if you build something)	How the software or prototype will be constructed and managed across the project timeline. This is a project management and engineering choice.	Prototyping, Iterative and Incremental, Spiral, V-Model, Agile / Kanban, Waterfall, Secure SDLC

Table 1. The two layers required in Chapter 3.

2.1 Why this distinction matters

Agile, Scrum, Waterfall and RAD are software process models. They describe how code is produced. They contain no problem statement logic, no data collection design, and no evaluation strategy. A proposal whose entire methodology is “we will use Agile” has not stated a methodology at all, and an examiner is entitled to say so.

Roughly half of the assigned research areas do not produce a software artefact. Groups E, H, R, U and V, and much of P and Q, are assessment, governance or empirical studies. Forcing an SDLC model onto a policy audit produces a Chapter 3 that reads as filler. In those cases the correct entry under Development Model is “Not applicable”, followed by one sentence explaining why.

2.2 What a complete Chapter 3 contains

- Research methodology selected, with its phases described in your own project's terms

- Development model, or a stated “Not applicable” with justification
- Justification paragraph — why this methodology suits this research problem
- Architecture diagram and flowchart
- Data collection procedures — dataset, test environment, or respondents
- Ethical and legal considerations
- Evaluation plan — baseline, metrics, and how success is decided
- Proposed timeline mapped to the phases of the selected methodology

3. Layer 1 — Research Methodology

Select ONE. If two seem to apply, choose the one that matches your primary contribution and mention the other as a supporting technique.

Methodology	Use it when your project...	Commonly suits groups
Design Science Research (Peppers DSRM; Hevner)	Builds a novel artefact — a tool, framework, protocol or model — and evaluates it against defined objectives. The dominant choice for build-type FYPs.	A, C, D, G, J, L, N, O, S, T, Z
Experimental / Quasi-experimental	Compares treatments under controlled conditions and reports measured results against a baseline.	F, I, M, W, X, Y
Data-driven (CRISP-DM / KDD)	Centres on datasets, feature engineering, model training and validation rather than on system construction.	K, M, P, V, Z
Security Assessment / Penetration Testing	Systematically probes a defined target and reports findings ranked by severity.	A, F, J, N, W, X
Threat Modelling and Risk Assessment	Produces a structured threat or risk picture, a control set, or a framework rather than code.	E, H, R, U, Y
Case Study (Yin) / Action Research	Studies or improves a real organisation, process or operational workflow in its own context.	E, H, R, Z
Survey / User Study	Measures human awareness, behaviour, perception or usability using an instrument.	H, U, V
Forensic Investigation Process Model	Follows defined evidence-handling phases with chain-of-custody rigour.	Q
Formal Verification / Analytic Proof	Proves security properties of a protocol, cipher or smart contract.	L, T
Systematic Literature Review (Kitchenham; PRISMA)	Synthesises an existing body of work. Best used as a component of another methodology; rarely sufficient alone at undergraduate level.	Any (as a component)

Table 2. Research methodologies and their typical fit.

3.1 Phases you are expected to describe

Whichever methodology you select, describe its phases in the language of your own project — not as a generic textbook diagram. The four most common choices are outlined below.

Methodology	Phases to describe in Chapter 3
Design Science Research	1. Problem identification and motivation → 2. Define objectives of a solution → 3. Design and development → 4. Demonstration → 5. Evaluation → 6. Communication
Experimental	1. Hypothesis and variables → 2. Experimental design and controls → 3. Environment and dataset setup → 4. Execution and measurement → 5. Statistical analysis → 6. Threats to validity
CRISP-DM	1. Business/security understanding → 2. Data understanding → 3. Data preparation → 4. Modelling → 5. Evaluation → 6. Deployment
Security Assessment (PTES)	1. Pre-engagement and scope authorisation → 2. Intelligence gathering → 3. Threat modelling → 4. Vulnerability analysis → 5. Exploitation in a controlled lab → 6. Post-exploitation → 7. Reporting

Table 3. Phase structures for the four most frequently selected methodologies.

4. Layer 2 — Development Model

Complete this section only if your project constructs a system, tool, prototype or pipeline. Otherwise write “Not applicable” and give one sentence of justification.

Model	Description	Best suited to
Prototyping (evolutionary or throwaway)	Build a working subset early, evaluate it, refine. The most honest fit for a single-semester project with uncertain requirements.	Most FYP prototypes; proof-of-concept work
Iterative and Incremental	Deliver the system in successive increments, each adding tested functionality. Safer and more credible than Scrum for a small team.	Detection tools; multi-module systems
Spiral (Boehm)	Risk-driven cycles in which risk analysis is a first-class activity in every iteration. Pedagogically strong for security work.	Security-critical systems; Groups A, G, Y
V-Model	Each development phase is paired with a matching verification or validation phase.	Safety- and assurance-driven work; Groups X, Y
Agile / Kanban	Continuous flow with a visible board and work-in-progress limits. Preferable to Scrum where the team is small.	Small teams delivering incrementally
Waterfall	Sequential phases with defined deliverables. Acceptable where requirements are genuinely fixed and known in advance.	Well-defined replication or porting work
DevSecOps pipeline model	The CI/CD pipeline with integrated SAST, DAST, SCA and container scanning is itself the process being studied.	Group S
Secure SDLC (Microsoft SDL, OWASP SAMM, NIST SSDF SP 800-218)	A security-engineering lifecycle with defined security activities and gates at each stage. Far more defensible than “Waterfall” for secure-development topics.	Groups D and S

Table 4. Development and process models.

4.1 A caution on Scrum

Scrum is usually a poor choice for a small student project. Sprint planning, daily stand-ups, and the distinct roles of Product Owner and Scrum Master cannot be genuinely enacted by a group of three or four students working part-time on one module. The chapter then becomes performative — a description of ceremonies that never took place. Kanban or plain iterative and incremental development is more credible and easier to evidence through your GitHub commit history.

5. Suggested Pairing by Research Area

These are starting points, not prescriptions. A different choice is perfectly acceptable if you can justify it against your specific problem statement.

Grp	Research Area	Suggested Research Methodology	Suggested Development Model
A	Cloud Security	Design Science Research, or Security Assessment (NIST SP 800-115)	Prototyping or Spiral
B	Biometric Security	Experimental, or Data-driven (CRISP-DM)	Iterative and Incremental
C	Data Loss Prevention	Design Science Research	Prototyping
D	Application Security	Design Science Research, or Security Assessment (OWASP ASVS)	Secure SDLC (Microsoft SDL / OWASP SAMM)
E	Information Security	Threat Modelling and Risk Assessment, or Case Study	Not applicable
F	Network Security	Experimental	Iterative and Incremental
G	IoT Security	Design Science Research, or Experimental	Spiral or Prototyping
H	Operational Security	Case Study, or Survey	Not applicable
I	Endpoint Security	Experimental, or Data-driven (CRISP-DM)	Iterative and Incremental
J	Website Security	Security Assessment (OWASP WSTG), or Design Science Research	Prototyping
K	Big Data Security	Data-driven (CRISP-DM), or Experimental	Iterative and Incremental
L	Blockchain Security	Design Science Research, or Formal Verification	Prototyping
M	AI Security	Experimental, or Data-driven (CRISP-DM)	Iterative and Incremental
N	Mobile Security	Security Assessment (OWASP MASTG), or Design Science Research	Prototyping
O	Identity and Access Management	Design Science Research	Prototyping or Spiral
P	Cyber Threat Intelligence	Data-driven (CRISP-DM)	Iterative and Incremental
Q	Digital Forensics and Incident Response	Forensic Investigation Process Model (NIST SP 800-86; ISO/IEC 27043)	Not applicable, or Prototyping if a tool is built
R	Governance, Risk and Compliance	Threat Modelling and Risk Assessment, or Case Study	Not applicable
S	DevSecOps Security	Design Science Research	DevSecOps pipeline model, or Secure SDLC
T	Cryptography and Key Management	Experimental, or Formal Verification	Prototyping
U	Privacy and Data Protection	Threat Modelling (LINDDUN), or Survey	Not applicable, or Prototyping

Grp	Research Area	Suggested Research Methodology	Suggested Development Model
V	Social Engineering and Phishing	Survey, or Data-driven (CRISP-DM) for detection	Not applicable, or Iterative
W	Wireless Security	Experimental, or Security Assessment	Prototyping
X	Automotive and Vehicle Security	Experimental, or Security Assessment	V-Model
Y	Cyber-Physical Systems and Critical Infrastructure	Experimental, or Threat Modelling and Risk Assessment	V-Model or Spiral
Z	Security Operations Centre and Threat Monitoring	Design Science Research, or Case Study	Iterative and Incremental

Table 5. Suggested methodology pairings for assigned research areas A–Z.

6. Domain Standards to Cite

Proposals score better when Chapter 3 anchors its process in an established standard rather than an invented flow diagram. Cite the standard, then show how your project instantiates it.

Domain	Standards and frameworks
Penetration testing and assessment	PTES; NIST SP 800-115; OSSTMM
Web and mobile security testing	OWASP WSTG; OWASP MASTG; OWASP ASVS
Threat modelling	STRIDE; PASTA; attack trees; MITRE ATT&CK; LINDDUN for privacy
Risk assessment	NIST SP 800-30; ISO/IEC 27005; OCTAVE Allegro; FAIR
Incident response and forensics	NIST SP 800-61; NIST SP 800-86; ISO/IEC 27037; ISO/IEC 27043; DFRWS process model
Governance, compliance and maturity	ISO/IEC 27001; ISO/IEC 27002; NIST Cybersecurity Framework; C2M2; OWASP SAMM
Secure development	Microsoft SDL; NIST SSDF (SP 800-218); OWASP SAMM
Protocol and smart contract verification	ProVerif; Tamarin; Scyther; Slither; Mythril
IoT and product security	ETSI EN 303 645; NIST IR 8259; OWASP IoT Top 10
Data analysis and empirical software engineering	CRISP-DM; Kitchenham guidelines for systematic reviews; Wohlin guidelines for experimentation

Table 6. Recognised standards by domain.

7. The Evaluation Plan

The single most common failure in a cybersecurity project is a working prototype with no evaluation. No baseline, no justification for the dataset, no metric beyond accuracy, and no threat model. State at proposal stage how you will demonstrate that your artefact works. If you cannot describe the evaluation, the objectives are not yet measurable.

7.1 What the plan must state

1. What is being measured, and why that quantity answers your research question.
2. The baseline you compare against — an existing published method, a standard algorithm, a current configuration, or a pre-intervention measurement.
3. The dataset or test environment, with its source, size and justification for being representative.
4. The metrics, defined precisely.
5. The threshold or condition under which you will regard the result as a success.

7.2 Metrics by project type

Project type	Typical metrics	Typical baseline
Detection or classification (ML-based)	Accuracy, precision, recall, F1-score, ROC-AUC, false positive rate, detection latency	A published model, or a classical algorithm on the same dataset
Lightweight cryptography / protocol	Execution time, memory footprint, energy consumption, key and ciphertext size, communication overhead	A standard scheme such as AES-128 or TLS on the same hardware
Web, mobile or network assessment	Number and severity of findings (CVSS), coverage against OWASP categories, remediation effect before and after	The unhardened system, or a published benchmark application
Framework, policy or GRC study	Control coverage against the reference standard, maturity score, expert validation ratings	The organisation's existing controls, or the reference standard itself
Human factors and awareness	Click rate, report rate, pre-test and post-test scores, instrument reliability (Cronbach's alpha)	Pre-intervention measurement, or a control group
Digital forensics	Evidence recovery rate, tool comparison, acquisition and analysis time, integrity verification by hash	An established forensic tool on the same disk or memory image
System or prototype	Functional test cases passed, throughput, latency, resource usage, usability (SUS score), user acceptance testing	The manual process, or the existing system being replaced

Table 7. Evaluation metrics and baselines by project type.

8. Ethical and Legal Scope

Every proposal must include an ethical and legal considerations subsection. Two categories of project carry specific obligations.

8.1 Projects involving human respondents

Groups H, U and V, and any project using surveys, interviews or simulated phishing, involve human subjects and require institutional ethics clearance before data collection begins.

- Obtain ethics approval before distributing any instrument
- Provide participants with an information sheet and obtain informed consent
- Anonymise responses; do not collect identifying data you do not need
- Never run a phishing simulation against real users without the documented, prior authorisation of the organisation concerned
- Comply with the Personal Data Protection Act 2010 (PDPA) when handling any personal data

8.2 Projects involving system testing

Groups A, F, I, J, N, W, X and Y involve probing or attacking systems. Unauthorised access to a computer system is an offence under the Computer Crimes Act 1997, and neither academic purpose nor curiosity is a defence.

- Testing must be confined to your own laboratory environment, a deliberately vulnerable target (DVWA, OWASP Juice Shop, Metasploitable), a licensed cyber range, or a system for which you hold written permission
- Isolate the test network; never expose a vulnerable target to the public internet
- Retain the written authorisation and cite it in the proposal
- Do not publish exploit code, live credentials, real logs, or the identity of a vulnerable third-party system
- Handle malware samples only in an isolated virtual machine with networking disabled

8.3 Declaration

Include the following statement, completed for your project, in Chapter 3:

All testing in this research will be conducted in [state the environment]. No testing will be carried out on any live or third-party system without prior written authorisation. [Where human respondents are involved:] Ethics approval will be obtained from the institutional committee prior to data collection, and participation will be voluntary, informed and anonymous.

9. Self-Check Before Submission

Work through this list against your draft Chapter 3. Each item corresponds to a defect that is regularly raised at proposal review.

No.	Check	If it fails
1	Have I named a research methodology, not only a development model?	Return to Section 3
2	Have I stated a development model, or written “Not applicable” with a reason?	Return to Section 4
3	Is there a justification paragraph explaining why both suit this problem?	Add one paragraph
4	Are the methodology phases described using my own project's activities rather than generic textbook wording?	Rewrite the phase descriptions
5	Does each research objective have a matching phase in the methodology?	Realign objectives and phases
6	Have I named a baseline for comparison?	Return to Section 7
7	Have I named the dataset or test environment and justified it?	Return to Section 7
8	Have I defined the evaluation metrics precisely?	Return to Table 7
9	Have I stated a threat model or attacker assumptions where relevant?	Add to Chapter 3
10	Have I cited a recognised domain standard rather than an invented process?	Return to Section 6
11	Have I completed the ethical and legal declaration?	Return to Section 8
12	Does the Gantt chart use the phases of my selected methodology as its rows?	Redraw the Gantt chart
13	Does Chapter 2 identify a gap that Chapter 3 actually addresses?	Revise the research gap
14	Are the architecture diagram and flowchart consistent with the GitHub repository?	Reconcile both

Table 8. Pre-submission self-check.

9.1 Frequent mistakes

- Naming Agile or Scrum as the research methodology
- Reproducing a generic SDLC diagram with no reference to the actual project
- Reporting accuracy alone on an imbalanced security dataset, where a trivial classifier scores highly
- Writing objectives that cannot be measured, such as “to enhance security”
- Presenting Chapter 2 as a list of paper summaries with no synthesis and no gap
- Building a prototype with no baseline to compare it against
- A Gantt chart whose rows are report chapters rather than methodology phases

10. References

- Boehm, B. W. (1988). A spiral model of software development and enhancement. *Computer*, 21(5), 61–72.
- Deng, M., Wuyts, K., Scandariato, R., Preneel, B., & Joosen, W. (2011). A privacy threat analysis framework. *Requirements Engineering*, 16(1), 3–32.
- Hevner, A. R., March, S. T., Park, J., & Ram, S. (2004). Design science in information systems research. *MIS Quarterly*, 28(1), 75–105.
- International Organization for Standardization. (2022). ISO/IEC 27001:2022 Information security management systems — Requirements.
- International Organization for Standardization. (2022). ISO/IEC 27005:2022 Guidance on managing information security risks.
- International Organization for Standardization. (2015). ISO/IEC 27043:2015 Incident investigation principles and processes.
- Kitchenham, B., & Charters, S. (2007). Guidelines for performing systematic literature reviews in software engineering (EBSE-2007-01). Keele University.
- National Institute of Standards and Technology. (2008). Technical guide to information security testing and assessment (SP 800-115).
- National Institute of Standards and Technology. (2012). Guide for conducting risk assessments (SP 800-30 Rev. 1).
- National Institute of Standards and Technology. (2022). Secure Software Development Framework (SP 800-218 Ver. 1.1).
- OWASP Foundation. (2024). OWASP Web Security Testing Guide; Mobile Application Security Testing Guide; Application Security Verification Standard.
- Peppers, K., Tuunanen, T., Rothenberger, M. A., & Chatterjee, S. (2007). A design science research methodology for information systems research. *Journal of Management Information Systems*, 24(3), 45–77.
- Penetration Testing Execution Standard. (2014). PTES technical guidelines.
- Shostack, A. (2014). *Threat modeling: Designing for security*. Wiley.
- Wohlin, C., Runeson, P., Höst, M., Ohlsson, M. C., Regnell, B., & Wesslén, A. (2012). *Experimentation in software engineering*. Springer.
- Yin, R. K. (2018). *Case study research and applications: Design and methods* (6th ed.). SAGE.